

References:

1. http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/D_through_E.html#GUID-76805E6F-9E89-4457-A9DC-5944C8FE5419

CIS Controls:

Version 6

16.4 Automatically Log Off Users After Standard Period Of Inactivity

Regularly monitor the use of all accounts, automatically logging off users after a standard period of inactivity.

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

1.2.8 Set 'exec-timeout' less than or equal to 10 minutes 'line tty' (Automated)

Profile Applicability:

- Level 1

Description:

If no input is detected during the interval, the EXEC facility resumes the current connection. If no connections exist, the EXEC facility returns the terminal to the idle state and disconnects the incoming session.

Rationale:

This prevents unauthorized users from misusing abandoned sessions. For example, if the network administrator leaves for the day and leaves a computer open with an enabled login session accessible. There is a trade-off here between security (shorter timeouts) and usability (longer timeouts). Review your local policies and operational needs to determine the best timeout value. In most cases, this should be no more than 10 minutes.

Impact:

Organizations should prevent unauthorized use of unattended or abandoned sessions by an automated control. Enabling 'exec-timeout' with an appropriate length reduces the risks of unauthorized access of abandoned sessions.

Audit:

Perform the following to determine if the timeout is configured:
Verify you return a result NOTE: If you set an exec-timeout of 10 minutes, this will not show up in the configuration

```
hostname#sh line tty <tty_line_number> | begin Timeout
```

Remediation:

Configure device timeout (10 minutes or less) to disconnect sessions after a fixed idle time.

```
hostname(config)#line tty {line_number} [ending_line_number]  
hostname(config-line)#exec-timeout <timeout_in_minutes> <timeout_in_seconds>
```

References:

1. http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/D_through_E.html#GUID-76805E6F-9E89-4457-A9DC-5944C8FE5419

CIS Controls:

Version 6

16.4 Automatically Log Off Users After Standard Period Of Inactivity

Regularly monitor the use of all accounts, automatically logging off users after a standard period of inactivity.

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

1.2.9 Set 'exec-timeout' to less than or equal to 10 minutes 'line vty' (Automated)

Profile Applicability:

- Level 1

Description:

If no input is detected during the interval, the EXEC facility resumes the current connection. If no connections exist, the EXEC facility returns the terminal to the idle state and disconnects the incoming session.

Rationale:

This prevents unauthorized users from misusing abandoned sessions. For example, if the network administrator leaves for the day and leaves a computer open with an enabled login session accessible. There is a trade-off here between security (shorter timeouts) and usability (longer timeouts). Review your local policies and operational needs to determine the best timeout value. In most cases, this should be no more than 10 minutes.

Impact:

Organizations should prevent unauthorized use of unattended or abandoned sessions by an automated control. Enabling 'exec-timeout' with an appropriate length of minutes or seconds prevents unauthorized access of abandoned sessions.

Audit:

Perform the following to determine if the timeout is configured:
Verify you return a result NOTE: If you set an exec-timeout of 10 minutes, this will not show up in the configuration

```
hostname#sh line vty <tty_line_number> | begin Timeout
```

Remediation:

Configure device timeout (10 minutes or less) to disconnect sessions after a fixed idle time.

```
hostname(config)#line vty {line_number} [ending_line_number]  
hostname(config-line)#exec-timeout <<span>timeout_in_minutes>  
<timeout_in_seconds</span>>
```

References:

1. http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/D_through_E.html#GUID-76805E6F-9E89-4457-A9DC-5944C8FE5419

CIS Controls:

Version 6

16.4 Automatically Log Off Users After Standard Period Of Inactivity

Regularly monitor the use of all accounts, automatically logging off users after a standard period of inactivity.

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

1.2.10 Set 'exec-timeout' to less than or equal to 10 minutes 'line vty' (Automated)

Profile Applicability:

- Level 1

Description:

If no input is detected during the interval, the EXEC facility resumes the current connection. If no connections exist, the EXEC facility returns the terminal to the idle state and disconnects the incoming session.

Rationale:

This prevents unauthorized users from misusing abandoned sessions. For example, if the network administrator leaves for the day and leaves a computer open with an enabled login session accessible. There is a trade-off here between security (shorter timeouts) and usability (longer timeouts). Review your local policies and operational needs to determine the best timeout value. In most cases, this should be no more than 10 minutes.

Impact:

Organizations should prevent unauthorized use of unattended or abandoned sessions by an automated control. Enabling 'exec-timeout' with an appropriate length of minutes or seconds prevents unauthorized access of abandoned sessions.

Audit:

Perform the following to determine if the timeout is configured:

Verify you return a result NOTE: If you set an exec-timeout of 10 minutes, this will not show up in the configuration

```
hostname#sh line vty <tty_line_number> | begin Timeout
```

Remediation:

Configure device timeout (10 minutes or less) to disconnect sessions after a fixed idle time.

```
hostname(config)#line vty {line_number} [ending_line_number]
hostname(config-line)#exec-timeout <<span>timeout_in_minutes>
<timeout_in_seconds</span>>
```

References:

1. http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/D_through_E.html#GUID-76805E6F-9E89-4457-A9DC-5944C8FE5419

CIS Controls:

Version 6

16.4 Automatically Log Off Users After Standard Period Of Inactivity

Regularly monitor the use of all accounts, automatically logging off users after a standard period of inactivity.

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

1.2.11 Set 'transport input none' for 'line aux 0' (Automated)

Profile Applicability:

- Level 1

Description:

When you want to allow only an outgoing connection on a line, use the no exec command.

Rationale:

Unused ports should be disabled, if not required, since they provide a potential access path for attackers. Some devices include both an auxiliary and console port that can be used to locally connect to and configure the device. The console port is normally the primary port used to configure the device; even when remote, backup administration is required via console server or Keyboard, Video, Mouse (KVM) hardware. The auxiliary port is primarily used for dial-up administration via an external modem; instead, use other available methods.

Impact:

Organizations should prevent all unauthorized access of auxiliary ports by disabling all protocols using the 'transport input none' command.

Audit:

Perform the following to determine if inbound connections for the aux port are disabled: Verify you see the following "Allowed input transports are none"

```
hostname#sh line aux 0 | incl input transports
```

Remediation:

Disable the inbound connections on the auxiliary port.

```
hostname(config)#line aux 0  
hostname(config-line)#transport input none
```

References:

1. http://www.cisco.com/en/US/docs/ios/termserv/command/reference/tsv_s1.html#wp1069219

CIS Controls:

Version 6

16.4 Automatically Log Off Users After Standard Period Of Inactivity

Regularly monitor the use of all accounts, automatically logging off users after a standard period of inactivity.

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

1.3 Banner Rules

Rules in the banner class communicate legal rights to users.

1.3.1 Set the 'banner-text' for 'banner exec' (Manual)

Profile Applicability:

- Level 1

Description:

This command specifies a message to be displayed when an EXEC process is created (a line is activated, or an incoming connection is made to a vty). Follow this command with one or more blank spaces and a delimiting character of your choice. Then enter one or more lines of text, terminating the message with the second occurrence of the delimiting character.

When a user connects to a router, the message-of-the-day (MOTD) banner appears first, followed by the login banner and prompts. After the user logs in to the router, the EXEC banner or incoming banner will be displayed, depending on the type of connection. For a reverse Telnet login, the incoming banner will be displayed. For all other connections, the router will display the EXEC banner.

Rationale:

"Network banners are electronic messages that provide notice of legal rights to users of computer networks. From a legal standpoint, banners have four primary functions.

- First, banners may be used to generate consent to real-time monitoring under Title III.
- Second, banners may be used to generate consent to the retrieval of stored files and records pursuant to ECPA.
- Third, in the case of government networks, banners may eliminate any Fourth Amendment "reasonable expectation of privacy" that government employees or other users might otherwise retain in their use of the government's network under *O'Connor v. Ortega*, 480 U.S. 709 (1987).
- Fourth, in the case of a non-government network, banners may establish a system administrator's "common authority" to consent to a law enforcement search pursuant to *United States v. Matlock*, 415 U.S. 164 (1974)." (US Department of Justice APPENDIX A: Sample Network Banner Language)

Impact:

Organizations provide appropriate legal notice(s) and warning(s) to persons accessing their networks by using a 'banner-text' for the banner exec command.

Audit:

Perform the following to determine if the exec banner is set:

```
hostname#sh running-config | beg banner exec
```

If the command does not return a result, the banner is not enabled

Remediation:

Configure the EXEC banner presented to a user when accessing the devices enable prompt.

```
hostname(config)#banner exec c
Enter TEXT message. End with the character 'c'.
<banner-text>
c
```

Default Value:

No banner is set by default

References:

1. [http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/A through B.html#GUID-0DEF5B57-A7D9-4912-861F-E837C82A3881](http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/A%20through%20B.html#GUID-0DEF5B57-A7D9-4912-861F-E837C82A3881)

Additional Information:

The default is no banner.

CIS Controls:

Version 7

5.1 Establish Secure Configurations

Maintain documented, standard security configuration standards for all authorized operating systems and software.

1.3.2 Set the 'banner-text' for 'banner login' (Manual)

Profile Applicability:

- Level 1

Description:

Follow the banner login command with one or more blank spaces and a delimiting character of your choice. Then enter one or more lines of text, terminating the message with the second occurrence of the delimiting character.

When a user connects to the router, the message-of-the-day (MOTD) banner (if configured) appears first, followed by the login banner and prompts. After the user successfully logs in to the router, the EXEC banner or incoming banner will be displayed, depending on the type of connection. For a reverse Telnet login, the incoming banner will be displayed. For all other connections, the router will display the EXEC banner.

Rationale:

"Network banners are electronic messages that provide notice of legal rights to users of computer networks. From a legal standpoint, banners have four primary functions.

- First, banners may be used to generate consent to real-time monitoring under Title III.
- Second, banners may be used to generate consent to the retrieval of stored files and records pursuant to ECPA.
- Third, in the case of government networks, banners may eliminate any Fourth Amendment "reasonable expectation of privacy" that government employees or other users might otherwise retain in their use of the government's network under *O'Connor v. Ortega*, 480 U.S. 709 (1987).
- Fourth, in the case of a non-government network, banners may establish a system administrator's "common authority" to consent to a law enforcement search pursuant to *United States v. Matlock*, 415 U.S. 164 (1974)." (US Department of Justice APPENDIX A: Sample Network Banner Language)

Impact:

Organizations provide appropriate legal notice(s) and warning(s) to persons accessing their networks by using a 'banner-text' for the banner login command.

Audit:

Perform the following to determine if the login banner is set:

```
hostname#show running-config | beg banner login
```

If the command does not return a result, the banner is not enabled.

Remediation:

Configure the device so a login banner presented to a user attempting to access the device.

```
hostname(config)#banner login c
Enter TEXT message. End with the character 'c'.
<banner-text>
c
```

Default Value:

No banner is set by default

References:

1. [http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/A through B.html#GUID-FF0B6890-85B8-4B6A-90DD-1B7140C5D22F](http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/A%20through%20B.html#GUID-FF0B6890-85B8-4B6A-90DD-1B7140C5D22F)

CIS Controls:

Version 7

17 Implement a Security Awareness and Training Program
Implement a Security Awareness and Training Program

1.3.3 Set the 'banner-text' for 'banner motd' (Manual)

Profile Applicability:

- Level 1

Description:

This MOTD banner is displayed to all terminals connected and is useful for sending messages that affect all users (such as impending system shutdowns). Use the no exec-banner or no motd-banner command to disable the MOTD banner on a line. The no exec-banner command also disables the EXEC banner on the line.

When a user connects to the router, the MOTD banner appears before the login prompt. After the user logs in to the router, the EXEC banner or incoming banner will be displayed, depending on the type of connection. For a reverse Telnet login, the incoming banner will be displayed. For all other connections, the router will display the EXEC banner.

Rationale:

"Network banners are electronic messages that provide notice of legal rights to users of computer networks. From a legal standpoint, banners have four primary functions.

- First, banners may be used to generate consent to real-time monitoring under Title III.
- Second, banners may be used to generate consent to the retrieval of stored files and records pursuant to ECPA.
- Third, in the case of government networks, banners may eliminate any Fourth Amendment "reasonable expectation of privacy" that government employees or other users might otherwise retain in their use of the government's network under O'Connor v. Ortega, 480 U.S. 709 (1987).
- Fourth, in the case of a non-government network, banners may establish a system administrator's "common authority" to consent to a law enforcement search pursuant to United States v. Matlock, 415 U.S. 164 (1974)." (US Department of Justice APPENDIX A: Sample Network Banner Language)

Impact:

Organizations provide appropriate legal notice(s) and warning(s) to persons accessing their networks by using a 'banner-text' for the banner motd command.

Audit:

Perform the following to determine if the login banner is set:

```
hostname#sh running-config | beg banner motd
```

If the command does not return a result, the banner is not enabled.

Remediation:

Configure the message of the day (MOTD) banner presented when a user first connects to the device.

```
hostname(config)#banner motd c
Enter TEXT message. End with the character 'c'.
<banner-text>
c
```

Default Value:

No banner is set by default

References:

1. [http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/A through B.html#GUID-7416C789-9561-44FC-BB2A-D8D8AFFB77DD](http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/A%20through%20B.html#GUID-7416C789-9561-44FC-BB2A-D8D8AFFB77DD)

CIS Controls:

Version 7

- 17 Implement a Security Awareness and Training Program
Implement a Security Awareness and Training Program

1.4 Password Rules

Rules in the password class enforce secure, local device authentication credentials.

1.4.1 Set 'password' for 'enable secret' (Automated)

Profile Applicability:

- Level 1

Description:

Use the enable secret command to provide an additional layer of security over the enable password. The enable secret command provides better security by storing the enable secret password using a nonreversible cryptographic function. The added layer of security encryption provides is useful in environments where the password crosses the network or is stored on a TFTP server.

Rationale:

Requiring the enable secret setting protects privileged EXEC mode. By default, a strong password is not required, a user can just press the Enter key at the Password prompt to start privileged mode. The enable password command causes the device to enforce use of a password to access privileged mode. Enable secrets use a one-way cryptographic hash (MD5). This is preferred to Level 7 enable passwords that use a weak, well-known, and easily reversible encryption algorithm.

Impact:

Organizations should protect privileged EXEC mode through policies requiring the 'enabling secret' setting, which enforces a one-way cryptographic hash (MD5).

Audit:

Perform the following to determine enable secret is set:

If the command does not return a result, the enable password is not set.

```
hostname#sh run | incl enable secret
```

Remediation:

Configure a strong, enable secret password.

```
hostname(config)#enable secret {ENABLE_SECRET_PASSWORD}
```

Default Value:

No enable secret password setup by default

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/security/d1/sec-cr-e1.html#GUID-944C261C-7D4A-49E1-AA8F-C754750BDE47>

Additional Information:

Note: You cannot recover a lost encrypted password. You must clear NVRAM and set a new password.

CIS Controls:

Version 6

5.8 Administrators Should Not Directly Log In To A System (i.e. use RunAs/sudo)

Administrators should be required to access a system using a fully logged and non-administrative account. Then, once logged on to the machine without administrative privileges, the administrator should transition to administrative privileges using tools such as Sudo on Linux/UNIX, RunAs on Windows, and other similar facilities for other types of systems.

Version 7

4.3 Ensure the Use of Dedicated Administrative Accounts

Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.

1.4.2 Enable 'service password-encryption' (Automated)

Profile Applicability:

- Level 1

Description:

When password encryption is enabled, the encrypted form of the passwords is displayed when a more system:running-config command is entered.

Rationale:

This requires passwords to be encrypted in the configuration file to prevent unauthorized users from learning the passwords just by reading the configuration. When not enabled, many of the device's passwords will be rendered in plain text in the configuration file. This service ensures passwords are rendered as encrypted strings preventing an attacker from easily determining the configured value.

Impact:

Organizations implementing 'service password-encryption' reduce the risk of unauthorized users learning clear text passwords to Cisco IOS configuration files. However, the algorithm used is not designed to withstand serious analysis and should be treated like clear-text.

Audit:

Perform the following to determine if a user with an encrypted password is enabled:
Ensure a result that matches the command return

```
hostname#sh run | incl service password-encryption
```

Remediation:

Enable password encryption service to protect sensitive access passwords in the device configuration.

```
hostname(config)#service password-encryption
```

Default Value:

Service password encryption is not set by default

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/security/s1/sec-cr-s1.html#GUID-CC0E305A-604E-4A74-8A1A-975556CE5871>

Additional Information:

Caution: This command does not provide a high level of network security. If you use this command, you should also take additional network security measures.

Note: You cannot recover a lost encrypted password. You must clear NVRAM and set a new password.

CIS Controls:

Version 6

16.14 Encrypt/Hash All Authentication Files And Monitor Their Access

Verify that all authentication files are encrypted or hashed and that these files cannot be accessed without root or administrator privileges. Audit all access to password files in the system.

Version 7

16.4 Encrypt or Hash all Authentication Credentials

Encrypt or hash with a salt all authentication credentials when stored.

1.4.3 Set 'username secret' for all local users (Automated)

Profile Applicability:

- Level 1

Description:

Use the username secret command to configure a username and MD5-encrypted user password. MD5 encryption is a strong encryption method that is not retrievable; thus, you cannot use MD5 encryption with protocols that require clear-text passwords, such as Challenge Handshake Authentication Protocol (CHAP).

The username secret command provides an additional layer of security over the username password. It also provides better security by encrypting the password using non reversible MD5 encryption and storing the encrypted text. The added layer of MD5 encryption is useful in environments in which the password crosses the network or is stored on a TFTP server.

Rationale:

Default device configuration does not require strong user authentication potentially enabling unfettered access to an attacker that is able to reach the device. Creating a local account with an encrypted password enforces login authentication and provides a fallback authentication mechanism for configuration in a named method list in a situation where centralized authentication, authorization, and accounting services are unavailable.

Impact:

Organizations implementing 'username secret' across their enterprise reduce the risk of unauthorized users gaining access to Cisco IOS devices by applying a MD5 hash and encrypting user passwords.

Audit:

Perform the following to determine if a user with an encrypted password is enabled:
If a result does not return with secret, the feature is not enabled

```
hostname#show run | incl username
```

Remediation:

Create a local user with an encrypted, complex (not easily guessed) password.

```
hostname(config)#username {{em}LOCAL_USERNAME{/em}} secret  
{{em}LOCAL_PASSWORD{/em}}
```

Default Value:

No passwords are set by default

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/security/s1/sec-cr-t2-z.html#GUID-5071E577-5249-4EA1-9226-BD426BEAD5B9>

CIS Controls:

Version 6

16.14 Encrypt/Hash All Authentication Files And Monitor Their Access

Verify that all authentication files are encrypted or hashed and that these files cannot be accessed without root or administrator privileges. Audit all access to password files in the system.

Version 7

16.4 Encrypt or Hash all Authentication Credentials

Encrypt or hash with a salt all authentication credentials when stored.

1.5 SNMP Rules

Simple Network Management Protocol (SNMP) provides a standards-based interface to manage and monitor network devices. This section provides guidance on the secure configuration of SNMP parameters.

The recommendations in this Section apply to Organizations using SNMP. Organizations using SNMP should review and implement the recommendations in this section.

1.5.1 Set 'no snmp-server' to disable SNMP when unused (Manual)

Profile Applicability:

- Level 1

Description:

If not in use, disable simple network management protocol (SNMP), read and write access.

Rationale:

SNMP read access allows remote monitoring and management of the device.

Impact:

Organizations not using SNMP should require all SNMP services to be disabled by running the 'no snmp-server' command.

Audit:

Verify the result reads "SNMP agent not enabled"

```
hostname#show snmp community
```

Remediation:

Disable SNMP read and write access if not in used to monitor and/or manage device.

```
hostname(config)#no snmp-server
```

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/snmp/command/nm-snmp-cr-book.html>

CIS Controls:

Version 6

9.1 Limit Open Ports, Protocols, and Services

Ensure that only ports, protocols, and services with validated business needs are running on each system.

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.